TÀI LIỆU ĐẶC TẢ API TÍCH HỢP

Hệ thống Mở tài khoản online có xác thực eKYC

Mã hợp đồng	N/A
Tên dự án	Mở tài khoản online có xác thực eKYC
Phân hệ	Đăng ký khách hàng / eKYC
Mã tài liệu	EKYC-API-SPEC-01
Phiên bản tài liệu	1.0 (Draft)

TRANG KÝ

I. SOẠN THẢO

TT	Họ tên	Chức vụ/Vai trò	Ngày ký	Chữ ký
1	Đào Đình Trung	BA	04/08/2026	Trung
2				
3				

II. KIỂM SOÁT

TT	Họ tên	Chức vụ/Vai trò	Ngày ký	Chữ ký
1				
2				
3				

III. PHÊ DUYỆT

TT	Họ tên	Chức vụ/Vai trò	Ngày ký	Chữ ký
1				
2				

BẢNG GHI NHẬN THAY ĐỔI PHIÊN BẢN

Ngày thay đổi	Phiên bản	Người thực hiện	Mô tả thay đổi
04/08/2026	1.0	Đào Đình Trung	Khởi tạo tài liệu đặc tả API cho luồng mở tài khoản eKYC.

MỤC LỤC

TRANG KÝ **2**
BẢNG GHI NHẬN THAY ĐỔI PHIÊN BẢN **3**
CÁC TỪ VIẾT TẮT **6**
I. GIỚI THIỆU **7**
1.1 Mục đích 7
1.2 Phạm vi 7
1.3 Tài liệu liên quan và giả định 7
II. KIẾN TRÚC TÍCH HỢP **8**
2.1 Sơ đồ kiến trúc logic 8
2.2 Luồng xử lý tổng quan 9
III. CHI TIẾT TÍCH HỢP (INTEGRATION & ENDPOINT) **10**
3.1 Quy ước chung 10
3.1.1 Base URL 10
3.1.2 Chuẩn dữ liệu và header 10
3.1.3 Response envelope 10
3.1.4 HTTP status sử dụng 10
3.2 Danh sách Service/API 11
3.3.1 API-01 - Gửi mã OTP 12
3.3.2 API-02 - Xác thực OTP 13
3.3.3 API-03 - Gửi ảnh CCCD để OCR 14
3.3.3 API-03 - Gửi ảnh CCCD để OCR (tiếp) 15
3.3.4 API-04 - Gửi ảnh khuôn mặt 16
3.3.4 API-04 - Gửi ảnh khuôn mặt (tiếp) 18
3.3.5 API-05 - Kiểm tra trạng thái hồ sơ 19
3.3.6 API-06 - Bổ sung thông tin đăng ký 20
3.3.7 API-07 - Xác nhận điều khoản và gửi hồ sơ 21
3.3.7 API-07 - Xác nhận điều khoản và gửi hồ sơ (tiếp) 22
3.3.8 API-08 - Thiết lập eBanking 23
3.3.9 EXT-01 - OCR trích xuất thông tin CCCD (Vendor) 24
3.3.9 EXT-01 - OCR trích xuất thông tin CCCD (Vendor) (tiếp) 25
3.3.10 EXT-02 - Face Matching và Liveness (Vendor) 26
IV. MÃ LỖI VÀ QUY TẮC NGHIỆP VỤ **27**
4.1 Bảng mã lỗi chuẩn 27
4.2 Quy tắc nghiệp vụ chính 28
V. BẢO MẬT TÍCH HỢP **28**
5.1 Xác thực và phân quyền 28
5.2 Bảo mật dữ liệu 29
5.3 Kiểm soát lỗi và dịch vụ phụ thuộc 29
VI. PHỤ LỤC **29**

6.1 Trạng thái hồ sơ 29
6.2 Danh sách nội dung cần xác nhận trước UAT 29

CÁC TỪ VIẾT TẮT

STT	Từ viết tắt	Giải thích nghĩa
1	API	Application Programming Interface - Giao diện lập trình ứng dụng
2	CCCD	Căn cước công dân
3	CIF	Customer Information File - Mã khách hàng trên Core Banking
4	eKYC	Electronic Know Your Customer - Định danh khách hàng điện tử
5	JWT	JSON Web Token
6	OCR	Optical Character Recognition - Nhận dạng ký tự quang học
7	OTP	One-Time Password - Mật khẩu sử dụng một lần
8	M/O/C	Mandatory / Optional / Conditional - Bắt buộc / Không bắt buộc / Có điều kiện

I. Giới thiệu

1.1 Mục đích

Tài liệu mô tả hợp đồng giao tiếp giữa Mobile App, hệ thống Backend của ngân hàng và dịch vụ eKYC bên thứ ba trong quy trình mở tài khoản online. Nội dung được sử dụng làm đầu vào cho thiết kế kỹ thuật, phát triển tích hợp và xây dựng test case API.

1.2 Phạm vi

Phạm vi tài liệu gồm hai nhóm giao tiếp:

- API do Bank Backend cung cấp cho Mobile App: gửi/xác thực OTP, tiếp nhận dữ liệu eKYC, cập nhật và gửi hồ sơ, thiết lập eBanking.
- API do vendor eKYC cung cấp cho Bank Backend: OCR CCCD, Face Matching và Liveness Detection.

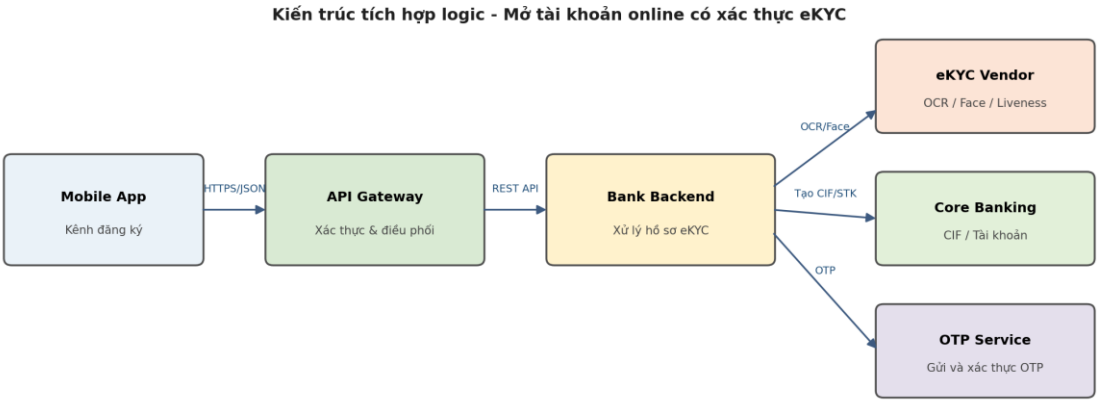
Tài liệu không mô tả thuật toán OCR/Face Matching nội bộ, cấu hình hạ tầng hoặc quy trình xét duyệt thủ công phía vận hành.

1.3 Tài liệu liên quan và giả định

Tài liệu/Đầu vào	Mục đích sử dụng
SRS - Mở tài khoản online có xác thực eKYC	Đối chiếu yêu cầu chức năng và phi chức năng.
Use Case / BPMN / Activity / Sequence Diagram	Đối chiếu luồng xử lý và các nhánh ngoại lệ.
Database Specification v1	Đối chiếu trường dữ liệu, trạng thái hồ sơ và quan hệ dữ liệu.
Tài liệu API chính thức của vendor	TBD - cần bổ sung và xác nhận trước khi triển khai tích hợp.

II. Kiến trúc tích hợp

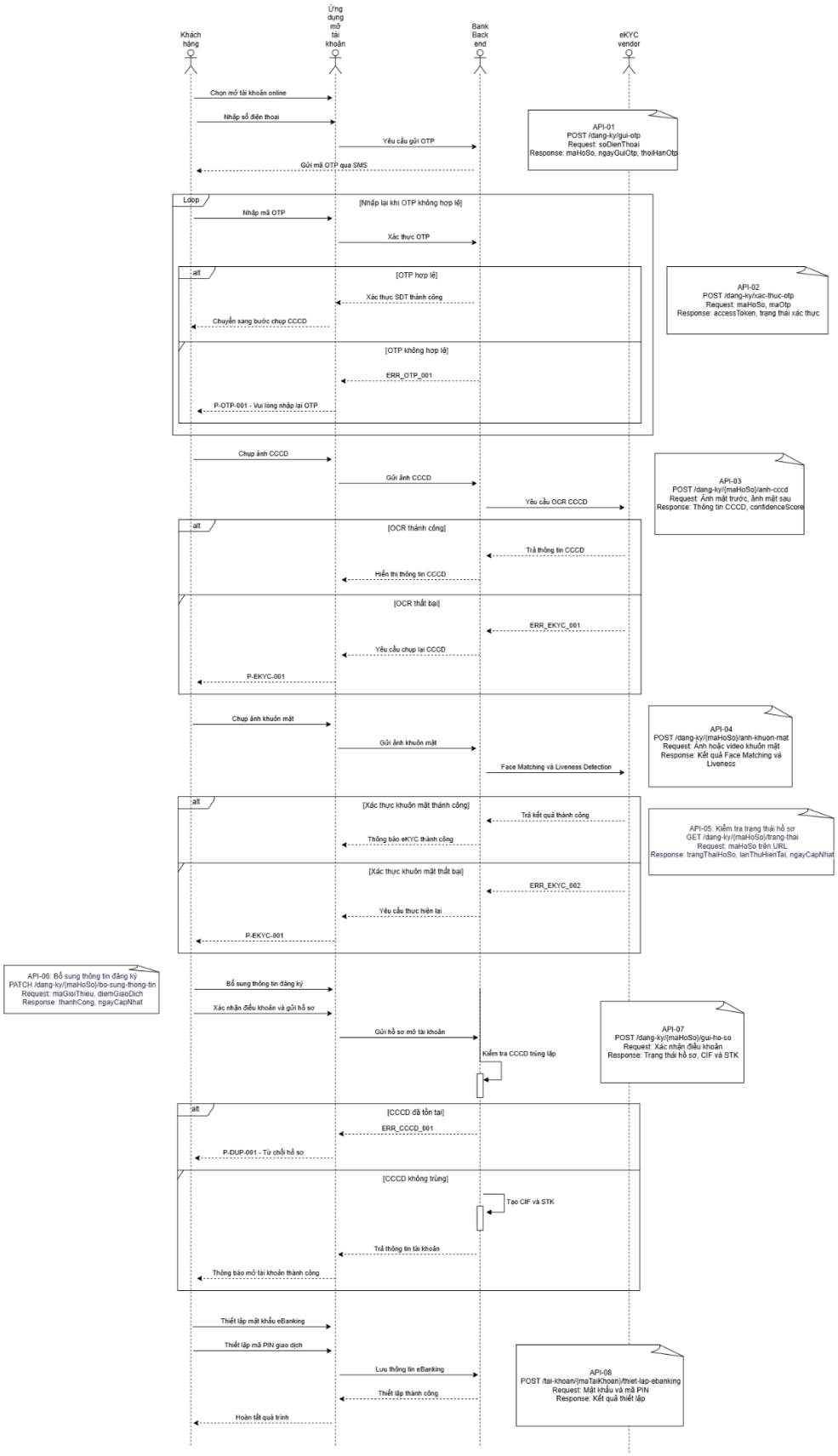
2.1 Sơ đồ kiến trúc logic



Hình 1. Kiến trúc tích hợp logic

Thành phần	Vai trò trong luồng
Mobile App	Thu thập dữ liệu đăng ký, ảnh CCCD, ảnh/video khuôn mặt và hiển thị kết quả.
API Gateway	Kiểm soát truy cập, chuyển tiếp request và áp dụng chính sách bảo mật/rate limit.
Bank Backend	Quản lý hồ sơ, điều phối eKYC, kiểm tra quy tắc nghiệp vụ và chuẩn hóa response.
eKYC Vendor	Cung cấp OCR, Face Matching và Liveness Detection.
Core Banking	Kiểm tra/tạo CIF và tài khoản khi hồ sơ đủ điều kiện.
OTP Service	Gửi và xác thực mã OTP theo số điện thoại.

2.2 Luồng xử lý tổng quan



Hình 2. Sequence Diagram của quy trình mở tài khoản eKYC (Link)

Lưu ý: Luồng trên thể hiện happy path. Các nhánh OTP sai/hết hạn, OCR hoặc Face Matching thất bại, CCCD trùng và dịch vụ vendor gián đoạn được mô tả tại từng API.

III. Chi tiết tích hợp (Integration & Endpoint)

3.1 Quy ước chung

3.1.1 Base URL

Nhóm API	Base URL	Ghi chú
Bank Backend	{{bank_api_base_url}}/v1	Cấu hình theo từng môi trường DEV/UAT/PROD.
eKYC Vendor	{{ekyc_vendor_base_url}}/v1	TBD - xác nhận theo tài liệu chính thức của vendor.

3.1.2 Chuẩn dữ liệu và header

- Encoding: UTF-8.
- Ngày giờ: ISO 8601, kèm offset +07:00.
- application/json cho API thông thường; multipart/form-data cho API upload ảnh/video.
- Mobile App gửi Authorization: Bearer <accessToken> sau khi xác thực OTP thành công.
- Bank Backend gọi vendor bằng X-API-Key hoặc cơ chế tương đương theo hợp đồng tích hợp.

3.1.3 Response envelope

Các API do Bank Backend cung cấp sử dụng cấu trúc response thống nhất:

```
{
 "success": true,
 "data": {},
 "error": null
}
```

Trường error chỉ có giá trị khi success = false; data trả về null trong trường hợp lỗi.

3.1.4 HTTP status sử dụng

HTTP status	Ý nghĩa
200 OK	Xử lý thành công.
201 Created	Tạo mới tài nguyên thành công.
400 Bad Request	Request không hợp lệ hoặc vi phạm điều kiện đầu vào.
401 Unauthorized	Thiếu hoặc sai thông tin xác thực.
404 Not Found	Không tìm thấy tài nguyên.
409 Conflict	Xung đột trạng thái hoặc dữ liệu.

HTTP status	Ý nghĩa
422 Unprocessable Entity	Dữ liệu đúng định dạng nhưng không đạt điều kiện nghiệp vụ.
429 Too Many Requests	Vượt tần suất gọi API.
500 Internal Server Error	Lỗi xử lý nội bộ.
503 Service Unavailable	Dịch vụ phụ thuộc tạm thời gián đoạn.

3.2 Danh sách Service/API

No.	Nhóm	ID	Method	Endpoint	Tên API
1	Mobile - Bank	API-01	POST	/dang-ky/gui-otp	Gửi mã OTP
2	Mobile - Bank	API-02	POST	/dang-ky/xac-thuc-otp	Xác thực OTP
3	Mobile - Bank	API-03	POST	/dang-ky/{maHoSo}/anh-cccd	Gửi ảnh CCCD để OCR
4	Mobile - Bank	API-04	POST	/dang-ky/{maHoSo}/anh-khuon-mat	Gửi ảnh khuôn mặt
5	Mobile - Bank	API-05	GET	/dang-ky/{maHoSo}/trang-thai	Kiểm tra trạng thái hồ sơ
6	Mobile - Bank	API-06	PATCH	/dang-ky/{maHoSo}/bo-sung-thong-tin	Bổ sung thông tin đăng ký
7	Mobile - Bank	API-07	POST	/dang-ky/{maHoSo}/gui-ho-so	Xác nhận điều khoản và gửi hồ sơ
8	Mobile - Bank	API-08	POST	/tai-khoan/{maTaiKhoan}/thiet-lap-ebanking	Thiết lập eBanking
9	Bank - Vendor	EXT-01	POST	/ocr	OCR trích xuất thông tin CCCD (Vendor)
10	Bank - Vendor	EXT-02	POST	/face-match	Face Matching và Liveness (Vendor)

Phạm vi: API-01 đến API-08 là contract do Bank Backend cung cấp. EXT-01 và EXT-02 là contract dự kiến với vendor, cần xác nhận trước khi phát triển.

3.3.1 API-01 - Gửi mã OTP

Mô tả: Tạo hồ sơ đăng ký ở trạng thái xử lý ban đầu và gửi mã OTP tới số điện thoại khách hàng.
URL (Endpoint): /dang-ky/gui-otp
Phương thức (Method): POST
Xác thực: Không yêu cầu access token
Content-Type: application/json
Use Case liên quan: UC01 - Xác thực số điện thoại

Request parameters

Field Name	Type	In	Mandatory	Description
soDienThoai	string	body	M	Số điện thoại Việt Nam, định dạng 0xxxxxxxxx.

Request example

```
{
 "soDienThoai": "0901234567"
}
```

Response data

Field Name	Type	Mandatory	Description
maHoSo	integer	M	Mã hồ sơ đăng ký vừa tạo.
ngayGuiOtp	datetime	M	Thời điểm gửi OTP theo ISO 8601.
thoiHanOtp	integer	M	Thời hạn hiệu lực của OTP, đơn vị giây; giá trị lấy từ cấu hình. Giá trị 300 trong response example chỉ mang tính minh họa, không phải Business Rule đã chốt.

Response example

```
{
 "success": true,
 "data": {
  "maHoSo": 1025,
  "ngayGuiOtp": "2026-08-04T09:15:00+07:00",
  "thoiHanOtp": 300
 },
 "error": null
}
```

Mã lỗi

HTTP	Error code	Tình huống
400	SDT_KHONG_HOP_LE	Số điện thoại không đúng định dạng.
429	QUA_NHIEU_YEU_CAU	Yêu cầu gửi OTP vượt tần suất cho phép.

Quy tắc/Ghi chú nghiệp vụ

- BR-01: OTP gồm 6 chữ số; thời hạn hiệu lực lấy theo cấu hình ngân hàng và chưa chốt ở mức nghiệp vụ.
- Không giới hạn số lần gửi lại theo nghiệp vụ; tần suất gọi do hạ tầng kiểm soát để chống spam.

3.3.2 API-02 - Xác thực OTP

Mô tả: Xác thực mã OTP khách hàng nhập. Nếu hợp lệ, hệ thống cấp access token cho các bước tiếp theo.

URL (Endpoint): /dang-ky/xac-thuc-otp

Phương thức (Method): POST

Xác thực: Không yêu cầu access token

Content-Type: application/json

Use Case liên quan: UC01 - Xác thực số điện thoại

Request parameters

Field Name	Type	In	Mandatory	Description
maHoSo	integer	body	M	Mã hồ sơ nhận từ API-01.
maOtp	string	body	M	Mã OTP khách hàng nhập.

Request example

```
{
 "maHoSo": 1025,
 "maOtp": "438219"
}
```

Response data

Field Name	Type	Mandatory	Description
hopLe	boolean	M	Kết quả xác thực OTP.
accessToken	string	M	JWT dùng cho các API tiếp theo.

Field Name	Type	Mandatory	Description
trangThaiHoSo	string	M	Trạng thái hồ sơ sau xác thực.

Response example

```
{
 "success": true,
 "data": {
  "hopLe": true,
  "accessToken": "eyJhbGciOi...",
  "trangThaiHoSo": "DangXuLy"
 },
 "error": null
}
```

Mã lỗi

HTTP	Error code	Tình huống
400	ERR_OTP_001	OTP không hợp lệ; hiển thị P-OTP-001 và cho phép nhập lại không giới hạn.
400	OTP_HET_HAN	Mã OTP đã hết hiệu lực.
404	HOSO_KHONG_TON_TAI	Không tìm thấy hồ sơ theo maHoSo.

Quy tắc/Ghi chú nghiệp vụ

- BR-02: Access token có thời hạn 30 phút kể từ thời điểm cấp.

3.3.3 API-03 - Gửi ảnh CCCD để OCR

Mô tả: Tiếp nhận ảnh mặt trước và mặt sau CCCD, gọi dịch vụ OCR của vendor và trả về thông tin trích xuất.

URL (Endpoint): /dang-ky/{maHoSo}/anh-cccd

Phương thức (Method): POST

Xác thực: Bearer access token

Content-Type: multipart/form-data

Use Case liên quan: UC03 - Chụp ảnh CCCD

Request parameters

Field Name	Type	In	Mandatory	Description
maHoSo	integer	path	M	Mã hồ sơ đăng ký.

Field Name	Type	In	Mandatory	Description
anhMatTruoc	file	form-data	M	Ảnh mặt trước CCCD.
anhMatSau	file	form-data	M	Ảnh mặt sau CCCD.

Request example

```
{
 "anhMatTruoc": "<front.jpg>",
 "anhMatSau": "<back.jpg>"
}
```

3.3.3 API-03 - Gửi ảnh CCCD để OCR (tiếp)

Response data

Field Name	Type	Mandatory	Description
ketQua	string	M	Pass hoặc Fail.
confidenceScore	decimal	M	Điểm tin cậy OCR từ 0 đến 100.
hoTen	string	C	Họ tên; trả về khi ketQua = Pass.
soCCCD	string	C	Số CCCD; trả về khi ketQua = Pass.
ngaySinh	date	C	Ngày sinh; trả về khi ketQua = Pass.
diaChi	string	C	Địa chỉ; trả về khi ketQua = Pass.
lanThuHienTai	integer	M	Số lần thử eKYC hiện tại.
coTheThuLai	boolean	M	Cho biết khách hàng còn được thử lại hay không.

Response example

```
{
 "success": true,
 "data": {
  "ketQua": "Pass",
  "confidenceScore": 96.8,
  "hoTen": "NGUYEN VAN AN",
  "soCCCD": "001090001001",
  "ngaySinh": "1990-01-15",
  "diaChi": "Ba Dinh, Ha Noi",
```

```
    "lanThuHienTai": 1,
    "coTheThuLai": true
  },
  "error": null
}
```

Mã lỗi

HTTP	Error code	Tình huống
401	TOKEN_KHONG_HOP_LE	Access token thiếu, sai hoặc hết hạn.
422	ERR_EKYC_001	OCR không trích xuất được thông tin CCCD; tổng thất bại eKYC < 3, hiển thị P-EKYC-001.
409	ERR_EKYC_003	Tổng thất bại eKYC đã đạt 3; hiển thị P-EKYC-002 và chuyển xét duyệt thủ công.

Quy tắc/Ghi chú nghiệp vụ

- BR-03: Kết quả OCR đạt khi confidenceScore >= 85.
- BR-04: Số lần thất bại được đếm chung giữa OCR và Face Matching; khi tổng thất bại đạt 3 thì chuyển xét duyệt thủ công.
- Khi đủ 3 lần thất bại, hồ sơ chuyển trạng thái ChoXetDuyetThuCong.

3.3.4 API-04 - Gửi ảnh khuôn mặt

Mô tả: Tiếp nhận ảnh hoặc video ngắn khuôn mặt, thực hiện Face Matching và Liveness Detection qua vendor eKYC.

URL (Endpoint): /dang-ky/{maHoSo}/anh-khuon-mat

Phương thức (Method): POST

Xác thực: Bearer access token

Content-Type: multipart/form-data

Use Case liên quan: UC04 - Chụp ảnh khuôn mặt

Request parameters

Field Name	Type	In	Mandatory	Description
maHoSo	integer	path	M	Mã hồ sơ đăng ký.
anhKhuonMat	file	form-data	M	Ảnh hoặc video ngắn khuôn mặt chụp trực tiếp.

Request example

```
{
  "anhKhuonMat": "<selfie.mp4>"
}
```

3.3.4 API-04 - Gửi ảnh khuôn mặt (tiếp)

Response data

Field Name	Type	Mandatory	Description
ketQua	string	M	Pass hoặc Fail.
confidenceScore	decimal	M	Điểm tin cậy so khớp khuôn mặt.
livenessPass	boolean	M	Kết quả kiểm tra liveness.
lanThuHienTai	integer	M	Số lần thử eKYC hiện tại.
coTheThuLai	boolean	M	Cho biết khách hàng còn được thử lại hay không.

Response example

```
{
 "success": true,
 "data": {
  "ketQua": "Pass",
  "confidenceScore": 94.6,
  "livenessPass": true,
  "lanThuHienTai": 1,
  "coTheThuLai": true
 },
 "error": null
}
```

Mã lỗi

HTTP	Error code	Tình huống
401	TOKEN_KHONG_HOP_LE	Access token thiếu, sai hoặc hết hạn.
422	ERR_EKYC_002	Face Matching dưới 85% hoặc Liveness Detection không đạt; tổng thất bại eKYC < 3, hiển thị P-EKYC-001.
409	ERR_EKYC_003	Tổng thất bại eKYC đã đạt 3; hiển thị P-EKYC-002 và chuyển xét duyệt thủ công.

Quy tắc/Ghi chú nghiệp vụ

- BR-03: Kết quả Face Matching đạt khi confidenceScore >= 85 và livenessPass = true.
- BR-04: Số lần thất bại được đếm chung với OCR; khi tổng thất bại đạt 3 thì chuyển xét duyệt thủ công.

3.3.5 API-05 - Kiểm tra trạng thái hồ sơ

Mô tả: Truy vấn trạng thái xử lý mới nhất của hồ sơ đăng ký.

URL (Endpoint): /dang-ky/{maHoSo}/trang-thai

Phương thức (Method): GET

Xác thực: Bearer access token

Content-Type: application/json

Use Case liên quan: UC02 - Theo dõi hồ sơ đăng ký

Request parameters

Field Name	Type	In	Mandatory	Description
maHoSo	integer	path	M	Mã hồ sơ đăng ký.

Request example

```
{
 "maHoSo": 1025
}
```

Response data

Field Name	Type	Mandatory	Description
trangThaiHoSo	string	M	DangXuLy, TuChoi, ChoXetDuyetThuCong hoặc HoanTat.
lanThuHienTai	integer	M	Số lần thử eKYC hiện tại.
ngayCapNhat	datetime	M	Thời điểm cập nhật trạng thái gần nhất.

Response example

```
{
 "success": true,
 "data": {
  "trangThaiHoSo": "DangXuLy",
  "lanThuHienTai": 1,
  "ngayCapNhat": "2026-08-04T09:22:10+07:00"
 },
 "error": null
}
```

Mã lỗi

HTTP	Error code	Tình huống
401	TOKEN_KHONG_HOP_LE	Access token thiếu, sai hoặc hết hạn.
404	HOSO_KHONG_TON_TAI	Không tìm thấy hồ sơ theo maHoSo.

3.3.6 API-06 - Bổ sung thông tin đăng ký

Mô tả: Cập nhật mã giới thiệu và/hoặc điểm giao dịch liên kết cho hồ sơ.
URL (Endpoint): /dang-ky/{maHoSo}/bo-sung-thong-tin
Phương thức (Method): PATCH
Xác thực: Bearer access token
Content-Type: application/json
Use Case liên quan: UC05 - Nhập thông tin bổ sung

Request parameters

Field Name	Type	In	Mandatory	Description
maHoSo	integer	path	M	Mã hồ sơ đăng ký.
maGioiThieu	string	body	O	Mã giới thiệu, nếu có.
diemGiaoDich	string	body	O	Điểm giao dịch khách hàng lựa chọn.

Request example

```
{
 "maGioiThieu": "GT001",
 "diemGiaoDich": "Chi nhanh Ba Dinh"
}
```

Response data

Field Name	Type	Mandatory	Description
thanhCong	boolean	M	Kết quả cập nhật.
ngayCapNhat	datetime	M	Thời điểm cập nhật gần nhất.

Response example


```
{
 "success": true,
 "data": {
  "thanhCong": true,
  "ngayCapNhat": "2026-08-04T09:25:00+07:00"
 },
 "error": null
}
```


Mã lỗi

HTTP	Error code	Tình huống
400	DU_LIEU_KHONG_HOP_LE	Thông tin bổ sung không đúng định dạng.
401	TOKEN_KHONG_HOP_LE	Access token thiếu, sai hoặc hết hạn.
404	HOSO_KHONG_TON_TAI	Không tìm thấy hồ sơ theo maHoSo.

Quy tắc/Ghi chú nghiệp vụ

- Hai trường maGioiThieu và diemGiaoDich đều không bắt buộc; chỉ cập nhật trường được truyền lên.

3.3.7 API-07 - Xác nhận điều khoản và gửi hồ sơ

Mô tả: Xác nhận điều khoản, kiểm tra CCCD trùng lặp và tạo khách hàng/CIF/tài khoản khi hồ sơ hợp lệ.

URL (Endpoint): /dang-ky/{maHoSo}/gui-ho-so

Phương thức (Method): POST

Xác thực: Bearer access token

Content-Type: application/json

Use Case liên quan: UC06 - Gửi hồ sơ đăng ký

Request parameters

Field Name	Type	In	Mandatory	Description
maHoSo	integer	path	M	Mã hồ sơ đăng ký.
xacNhanDieuKhoan	boolean	body	M	Phải bằng true để tiếp tục xử lý.

Request example

```
{
 "xacNhanDieuKhoan": true
}
```

3.3.7 API-07 - Xác nhận điều khoản và gửi hồ sơ (tiếp)

Response data

Field Name	Type	Mandatory	Description
trangThaiHoSo	string	M	HoanTat khi tạo tài khoản thành công.
maTaiKhoan	integer	M	Khóa định danh tài khoản trong hệ thống.
soTaiKhoan	string	M	Số tài khoản thanh toán được cấp.
maCIF	string	M	Mã khách hàng trên Core Banking.

Response example

```
{
 "success": true,
 "data": {
  "trangThaiHoSo": "HoanTat",
  "maTaiKhoan": 8801,
  "soTaiKhoan": "100000000001",
  "maCIF": "CIF000001"
 },
 "error": null
}
```

Mã lỗi

HTTP	Error code	Tình huống
400	CHUA_XAC_NHAN_DIEU_KHOAN	Khách hàng chưa xác nhận điều khoản.
409	ERR_CCCD_001	CCCD đã tồn tại trong dữ liệu khách hàng chính thức; hiển thị P-DUP-001 và từ chối hồ sơ.
422	HOSO_CHUA_DU_DIEU_KIEN	Hồ sơ chưa hoàn tất các bước eKYC bắt buộc.

Quy tắc/Ghi chú nghiệp vụ

- BR-05: Kiểm tra trùng CCCD với dữ liệu khách hàng chính thức, không so với hồ sơ nháp hoặc hồ sơ đã từ chối.
- BR-06: Chỉ tiếp tục khi xacNhanDieuKhoan = true.

3.3.8 API-08 - Thiết lập eBanking

Mô tả: Thiết lập mật khẩu đăng nhập và mã PIN giao dịch cho tài khoản eBanking vừa mở.
URL (Endpoint): /tai-khoan/{maTaiKhoan}/thiet-lap-ebanking
Phương thức (Method): POST
Xác thực: Bearer access token
Content-Type: application/json
Use Case liên quan: UC09 - Thiết lập eBanking

Request parameters

Field Name	Type	In	Mandatory	Description
maTaiKhoan	integer	path	M	Mã tài khoản nhận từ API-07.
matKhau	string	body	M	Tối thiểu 8 ký tự, có chữ và số.
maPin	string	body	M	Mã PIN gồm 6 chữ số.

Request example

```
{
 "matKhau": "Demo@2026",
 "maPin": "836214"
}
```

Response data

Field Name	Type	Mandatory	Description
thanhCong	boolean	M	Kết quả thiết lập eBanking.
ngayThietLap	datetime	M	Thời điểm thiết lập thành công.

Response example

```
{
 "success": true,
 "data": {
  "thanhCong": true,
  "ngayThietLap": "2026-08-04T09:31:00+07:00"
```

```
  },
  "error": null
}
```

Mã lỗi

HTTP	Error code	Tình huống
400	MAT_KHAU_KHONG_DU_MANH	Mật khẩu không đạt yêu cầu độ mạnh.
400	MA_PIN_KHONG_HOP_LE	Mã PIN không đúng định dạng.
409	EBANKING_DA_THIET_LAP	Tài khoản đã có cấu hình eBanking.

Quy tắc/Ghi chú nghiệp vụ

- BR-07: Mật khẩu tối thiểu 8 ký tự, có chữ và số; PIN gồm đúng 6 chữ số.
- Mật khẩu và PIN chỉ được lưu dưới dạng hash; không ghi plaintext vào database hoặc log.

3.3.9 EXT-01 - OCR trích xuất thông tin CCCD (Vendor)

Mô tả: API dự kiến do vendor eKYC cung cấp để trích xuất thông tin từ ảnh CCCD gắn chip.
URL (Endpoint): /ocr
Phương thức (Method): POST
Xác thực: X-API-Key
Content-Type: application/json
Use Case liên quan: Tích hợp nội bộ của API-03

Request parameters

Field Name	Type	In	Mandatory	Description
anhMatTruoc	base64 string	body	M	Ảnh mặt trước CCCD đã mã hóa base64.
anhMatSau	base64 string	body	M	Ảnh mặt sau CCCD đã mã hóa base64.

Request example

```
{
  "anhMatTruoc": "<base64_front>",
  "anhMatSau": "<base64_back>"
}
```

3.3.9 EXT-01 - OCR trích xuất thông tin CCCD (Vendor) (tiếp)

Response data

Field Name	Type	Mandatory	Description
ketQua	string	M	Pass hoặc Fail.
confidenceScore	decimal	M	Điểm tin cậy OCR từ 0 đến 100.
hoTen	string	C	Họ tên trích xuất.
soCCCD	string	C	Số CCCD trích xuất.
ngaySinh	date	C	Ngày sinh trích xuất.
diaChi	string	C	Địa chỉ trích xuất.

Response example

```
{
 "ketQua": "Pass",
 "confidenceScore": 96.8,
 "hoTen": "NGUYEN VAN AN",
 "soCCCD": "001090001001",
 "ngaySinh": "1990-01-15",
 "diaChi": "Ba Dinh, Ha Noi"
}
```

Mã lỗi

HTTP	Error code	Tình huống
422	IMAGE_UNREADABLE	Ảnh không đọc được.
503	SERVICE_UNAVAILABLE	Dịch vụ eKYC tạm thời gián đoạn.

Quy tắc/Ghi chú nghiệp vụ

- Contract này là đề xuất tích hợp. Tên trường, cơ chế ký request và mã lỗi phải đối chiếu tài liệu chính thức của vendor trước khi phát triển.

3.3.10 EXT-02 - Face Matching và Liveness (Vendor)

Mô tả: API dự kiến do vendor eKYC cung cấp để so khớp khuôn mặt và kiểm tra liveness.
URL (Endpoint): /face-match
Phương thức (Method): POST
Xác thực: X-API-Key
Content-Type: application/json
Use Case liên quan: Tích hợp nội bộ của API-04

Request parameters

Field Name	Type	In	Mandatory	Description
anhCCCD	base64/ref	body	M	Ảnh khuôn mặt trích từ CCCD hoặc mã tham chiếu do vendor cấp.
anhKhuonMat	base64 string	body	M	Ảnh/video khuôn mặt chụp trực tiếp.

Request example

```
{
 "anhCCCD": "<base64_or_ref>",
 "anhKhuonMat": "<base64_selfie>"
}
```

Response data

Field Name	Type	Mandatory	Description
ketQua	string	M	Pass hoặc Fail.
confidenceScore	decimal	M	Điểm tin cậy so khớp từ 0 đến 100.
livenessPass	boolean	M	Kết quả kiểm tra liveness.

Response example

```
{
 "ketQua": "Pass",
 "confidenceScore": 94.6,
 "livenessPass": true
}
```

Mã lỗi

HTTP	Error code	Tình huống
422	LIVENESS_FAILED	Phát hiện nguy cơ giả mạo hoặc liveness không đạt.
503	SERVICE_UNAVAILABLE	Dịch vụ eKYC tạm thời gián đoạn.

Quy tắc/Ghi chú nghiệp vụ

- Contract này là đề xuất tích hợp và cần được vendor xác nhận trước khi phát triển.

IV. Mã lỗi và quy tắc nghiệp vụ

4.1 Bảng mã lỗi chuẩn

Error code	HTTP	Mô tả
SDT_KHONG_HOP_LE	400	Số điện thoại không đúng định dạng.
ERR_OTP_001	400	OTP không hợp lệ; hiển thị P-OTP-001 và cho phép nhập lại không giới hạn.
OTP_HET_HAN	400	Mã OTP hết hiệu lực.
DU_LIEU_KHONG_HOP_LE	400	Dữ liệu đầu vào không hợp lệ.
CHUA_XAC_NHAN_DIEU_KHOAN	400	Chưa xác nhận điều khoản sử dụng.
MAT_KHAU_KHONG_DU_MANH	400	Mật khẩu không đạt yêu cầu.
MA_PIN_KHONG_HOP_LE	400	Mã PIN không đúng định dạng.
TOKEN_KHONG_HOP_LE	401	Access token thiếu, sai hoặc hết hạn.
HOSO_KHONG_TON_TAI	404	Không tìm thấy hồ sơ.
ERR_CCCD_001	409	CCCD đã tồn tại trong dữ liệu khách hàng chính thức; hiển thị P-DUP-001 và từ chối hồ sơ.
ERR_EKYC_003	409	Tổng thất bại eKYC đã đạt 3; hiển thị P-EKYC-002 và chuyển xét duyệt thủ công.
EBANKING_DA_THIET_LAP	409	Tài khoản đã thiết lập eBanking.

Error code	HTTP	Mô tả
ERR_EKYC_001	422	OCR không trích xuất được thông tin CCCD; khi tổng thất bại eKYC < 3, hiển thị P-EKYC-001.
ERR_EKYC_002	422	Face Matching dưới 85% hoặc Liveness Detection không đạt; khi tổng thất bại eKYC < 3, hiển thị P-EKYC-001.
HOSO_CHUA_DU_DIEU_KIEN	422	Hồ sơ chưa đủ điều kiện gửi.
QUA_NHIEU_YEU_CAU	429	Vượt tần suất gọi API cho phép.
LOI_HE_THONG	500	Lỗi hệ thống không xác định.
SERVICE_UNAVAILABLE	503	Dịch vụ phụ thuộc tạm thời gián đoạn.

4.2 Quy tắc nghiệp vụ chính

Rule ID	Nội dung
BR-01	OTP gồm 6 chữ số; thời hạn hiệu lực lấy theo cấu hình ngân hàng và chưa chốt ở mức nghiệp vụ.
BR-02	Access token cấp sau OTP có thời hạn 30 phút.
BR-03	Ngưỡng đạt OCR/Face Matching là 85; Face Matching chỉ đạt khi livenessPass = true.
BR-04	Số lần thất bại OCR và Face Matching được đếm chung; khi tổng thất bại đạt 3 thì chuyển xét duyệt thủ công.
BR-05	Kiểm tra trùng CCCD với khách hàng chính thức tại thời điểm gửi hồ sơ.
BR-06	Chỉ gửi hồ sơ khi khách hàng đã xác nhận điều khoản.
BR-07	Mật khẩu tối thiểu 8 ký tự, có chữ và số; PIN gồm 6 chữ số; chỉ lưu giá trị hash.

V. Bảo mật tích hợp

5.1 Xác thực và phân quyền

- Mobile App sử dụng JWT Bearer Token đối với API yêu cầu đăng nhập phiên đăng ký.
- Thông tin xác thực với vendor được lưu tại secret store của môi trường triển khai; không hard-code trong mã nguồn.
- Bank Backend kiểm tra quyền truy cập hồ sơ theo token và maHoSo trước khi trả dữ liệu.

5.2 Bảo mật dữ liệu

- Toàn bộ kết nối sử dụng HTTPS/TLS theo tiêu chuẩn của ngân hàng.
- Không ghi log OTP, access token, mật khẩu, PIN hoặc ảnh eKYC ở dạng có thể khai thác lại.
- Mật khẩu và PIN chỉ được lưu dưới dạng hash; dữ liệu nhạy cảm trên log phải được masking.

5.3 Kiểm soát lỗi và dịch vụ phụ thuộc

- Không trả stack trace hoặc thông tin hạ tầng nội bộ cho Mobile App.
- Khi vendor eKYC gián đoạn, Bank Backend trả mã SERVICE_UNAVAILABLE và không tự động tăng số lần thất bại nghiệp vụ của khách hàng.
- Rate limit cụ thể theo từng môi trường là TBD và do đội hạ tầng/bảo mật xác nhận.

Điểm cần xác nhận: Cơ chế ký request tới vendor, thời gian timeout, retry policy, dung lượng file tối đa và định dạng ảnh/video được chấp nhận.

VI. Phụ lục

6.1 Trạng thái hồ sơ

Giá trị	Ý nghĩa
DangXuLy	Hồ sơ đang được khách hàng hoàn thiện hoặc hệ thống đang xử lý.
TuChoi	Hồ sơ không đủ điều kiện và đã bị từ chối.
ChoXetDuyetThuCong	Hồ sơ cần bộ phận nghiệp vụ kiểm tra thủ công.
HoanTat	Hồ sơ đã hoàn tất và khách hàng/tài khoản đã được tạo.

6.2 Danh sách nội dung cần xác nhận trước UAT

- Base URL theo từng môi trường và cơ chế định tuyến qua API Gateway.
- Contract chính thức của EXT-01/EXT-02 và cơ chế xác thực với vendor.
- Dung lượng, định dạng ảnh/video và timeout của các API upload.
- Chính sách retry khi OTP Service, Core Banking hoặc eKYC Vendor gián đoạn.
- Bộ mã lỗi cuối cùng và message hiển thị trên Mobile App.
- Cơ chế xử lý hồ sơ ChoXetDuyetThuCong và SLA phản hồi khách hàng.

Kết thúc tài liệu: Các thay đổi contract sau khi review cần được cập nhật vào bảng lịch sử phiên bản và thông báo cho Backend, Mobile và QA trước khi triển khai.